

 STOCKWHISK SAAS PLATFORM

DOC-11

Security & Multi-Tenant Penetration Test Scenarios

Threat Models, Cross-Tenant Leaks, RBAC Bypasses & Throttling Audits

DOCUMENT TYPE

Security Test Suite

TARGET AUDIENCE

Security Engineers,
Penesting Teams

RELEASE VERSION

v1.4.0 Production

STATUS

 Verified & Approved

Security Test Scenarios

This document outlines detailed security test scenarios for the StockWhisk SaaS project.

Authentication (ST-AUTH-xxx)

TEST ID	TEST NAME	PRECONDITIONS	STEPS	EXPECTED RESULT	PRIORITY
ST-AUTH-001	Login with valid credentials	User exists	1. Enter valid email/password 2. Submit	User logged in; JWT token returned	P1
ST-AUTH-002	Login with invalid credentials	User exists	1. Enter invalid password 2. Submit	Login failed; generic error message	P1
ST-AUTH-003	JWT token expiry	User is logged in	1. Wait for token expiration 2. Attempt API call	401 Unauthorized; User prompted to re-login or refresh	P1
ST-AUTH-004	Token refresh	Refresh token is valid	1. Call refresh endpoint	New access token issued	P1
ST-AUTH-005	Brute force lockout	User exists	1. Attempt invalid login 10 times	Account temporarily locked; 429/403 returned	P2
ST-AUTH-006	Password reset	User forgets password	1. Request reset link 2. Use link to set new password	Password updated securely; old tokens invalidated	P2

Authorization (ST-AUTHZ-xxx)

TEST ID	TEST NAME	PRECONDITIONS	STEPS	EXPECTED RESULT	PRIORITY
ST-AUTHZ-001	Cashier access control	Logged in as Cashier	1. Attempt to access Admin Settings via URL/API	403 Forbidden; UI hides option	P1
ST-AUTHZ-002	Manager user management	Logged in as Manager w/o user perms	1. Attempt to create new user	403 Forbidden	P1
ST-AUTHZ-003	Owner full access	Logged in as Owner	1. Access all modules	Full read/write access granted	P1
ST-AUTHZ-004	Permission boundary	User has only 'View Sales'	1. Attempt to 'Edit Sale' via API	403 Forbidden	P1

Tenant Isolation (ST-TENANT-xxx)

TEST ID	TEST NAME	PRECONDITIONS	STEPS	EXPECTED RESULT	PRIORITY
ST-TENANT-001	Cross-tenant product isolation	Shop A and Shop B exist	1. Login to Shop A 2. Query products	Only Shop A products returned	P1
ST-TENANT-002	Cross-tenant ID manipulation	Shop B invoice ID is 500	1. Login to Shop A 2. Request <code>/api/invoices/500/</code>	404 Not Found (or 403)	P1
ST-TENANT-003	API response integrity	Standard API call	1. Fetch sales list	Verify no <code>tenant_id</code> from other shops leaked	P1
ST-TENANT-004	Bulk operation boundaries	Upload CSV products	1. Upload generic CSV	Products strictly bound to uploader's tenant	P1
ST-TENANT-005	File upload isolation	Shop A uploads logo	1. Shop B attempts to access URL (if private)	Access denied / strict scoping applied	P2

Data Validation (ST-DATA-xxx)

TEST ID	TEST NAME	PRECONDITIONS	STEPS	EXPECTED RESULT	PRIORITY
ST-DATA-001	SQL injection prevention	Search input	1. Enter ' OR 1=1; -- in search	Input sanitized; no SQL execution	P1
ST-DATA-002	XSS prevention	Customer creation	1. Enter <script>alert(1)</script> as name	Script tags escaped/stripped on render	P1
ST-DATA-003	Negative quantity rejection	POS / API	1. Submit cart with qty -5	Validation error; 400 Bad Request	P1
ST-DATA-004	Price validation	POS / API	1. Submit sale with negative price	Validation error	P1
ST-DATA-005	Required field enforcement	Product creation	1. Submit without Name	400 Bad Request; clear error message	P2

Rate Limiting (ST-RATE-xxx)

TEST ID	TEST NAME	PRECONDITIONS	STEPS	EXPECTED RESULT	PRIORITY
ST-RATE-001	API throttling	Normal user	1. Send 1000 requests in 1 minute	429 Too Many Requests after threshold	P2
ST-RATE-002	Burst rate limiting	Normal user	1. Send 50 concurrent requests instantly	Regulated by burst allowance; excess rejected	P2

Demo Mode (ST-DEMO-xxx)

TEST ID	TEST NAME	PRECONDITIONS	STEPS	EXPECTED RESULT	PRIORITY
ST-DEMO-001	Write operation block	Tenant is Demo Shop	1. Attempt to create sale / edit product	Operation blocked; "Demo mode" message	P2
ST-DEMO-002	Read operation allow	Tenant is Demo Shop	1. View dashboard, reports	Data loads successfully	P2

Impersonation (ST-IMP-xxx)

TEST ID	TEST NAME	PRECONDITIONS	STEPS	EXPECTED RESULT	PRIORITY
ST-IMP-001	Admin impersonation	Superadmin user	1. Click impersonate Shop A	Logged in context changes to Shop A	P1
ST-IMP-002	Impersonation audit trail	Admin impersonates	1. Perform action as Shop A	Action logged with Admin's original ID in audit	P2
ST-IMP-003	Non-admin restriction	Regular tenant user	1. Attempt impersonation API call	403 Forbidden	P1